



— AXE D · LES SERVICES DE CERTIFICATS AD CS

L'autorité qui signe des badges à votre place

Votre PKI ne fabrique pas que des cadenas pour le navigateur — elle fabrique des pièces d'identité que le domaine accepte sans broncher.

Demandez à qui appartient la PKI de votre organisation. On vous renverra vers l'équipe réseau, ou vers celui qui « gère les certificats Wi-Fi ». Personne ne la citera comme un sujet de sécurité de l'annuaire. C'est pourtant l'une des routes les plus directes — et les plus discrètes — vers les clés du domaine.

L'IDÉE REÇUE

« Notre PKI, c'est pour le HTTPS et le Wi-Fi — un sujet réseau, pas un sujet sécurité. »

En réalité — un certificat délivré par AD CS n'est pas qu'un cadenas pour le navigateur : c'est une **pièce d'identité** que le domaine accepte pour authentifier un compte. Un seul modèle de certificat trop permissif, et l'autorité signe — à qui le demande — un badge au nom de l'administrateur.

Un modèle, une élévation

ESC1

Quand un modèle laisse le demandeur choisir lui-même l'identité inscrite dans le certificat, n'importe quel compte peut réclamer un badge « Administrateur du domaine ». L'autorité le signe, et l'annuaire l'accepte.

AU SOMMAIRE DE CETTE FICHE

1

Le déclic

L'idée reçue, l'analogie du badge, l'impact métier.

2

Le mécanisme

PKINIT, l'anatomie d'un modèle, les quatre conditions d'ESC1.

3

La salle des machines

Vérifier, comprendre l'attaque, corriger et détecter.

1

NIVEAU 1 — POUR COMPRENDRE

Le déclic

Le mot « certificat » évoque pour nous une seule image : le petit cadenas dans la barre du navigateur. Un certificat, c'est ce qui rend un site « sécurisé », ce qui chiffre une connexion Wi-Fi. Un objet technique, utile, et résolument du ressort de l'équipe réseau.

Cette image est exacte, mais elle est partielle. Un certificat sait faire bien plus que chiffrer : il sait aussi *prouver une identité*. Et dans un domaine Active Directory, prouver son identité, c'est exactement ce qu'on appelle s'authentifier.

Prenons une image. Une entreprise possède une machine à fabriquer les badges du personnel. Ce que la machine imprime sert d'ordinaire à des choses anodines : ouvrir le parking, accéder à la cafétéria. Mais le badge porte aussi une photo et

un nom — et le service de sécurité, à l'entrée, accepte ce badge comme preuve d'identité.

Toute la question devient alors : **qui décide du nom imprimé sur le badge ?** Si c'est le service des ressources humaines, après vérification, tout va bien. Mais si la machine est réglée pour laisser le demandeur taper lui-même le nom de son choix, alors n'importe qui peut repartir avec un badge au nom du directeur.

Cette machine à badges, dans Active Directory, c'est l'autorité de certification, le cœur d'**AD CS**. Le réglage qui décide « qui choisit le nom » porte un nom de modèle de certificat. Et lorsqu'il est mal réglé, l'autorité signe consciencieusement des pièces d'identité au nom de n'importe qui — administrateur du domaine compris.

« Un certificat ne fait pas que chiffrer une connexion : il atteste qui vous êtes. Et le domaine le croit sur parole. »

POURQUOI ÇA COMPTE — L'IMPACT MÉTIER

Une PKI mal configurée est une cible idéale, pour une raison qui tient à l'organisation autant qu'à la technique : elle se trouve souvent dans un angle mort. Installée pour un besoin précis — le Wi-Fi, un portail web — elle est gérée comme un outil réseau, par une équipe qui n'a pas toujours le réflexe de la sécurité de l'annuaire. Ses modèles de certificats ne sont presque jamais audités. Or un certificat d'authentification, une fois émis, est un sésame valable des mois durant, qui survit même à un changement de mot de passe. Pour un attaquant, c'est à la fois une élévation de privilèges et un mécanisme de persistance — le tout livré, signé, par un service interne de confiance.

2

NIVEAU 2 — LE FONCTIONNEMENT RÉEL

Le mécanisme

Au départ se trouve une fonctionnalité légitime de Kerberos : **PKINIT**. Elle permet à un compte de présenter un certificat — au lieu d'un mot de passe — pour obtenir son laissez-passer maître, le TGT. C'est ce qui fait fonctionner la carte à puce. Le contrôleur de domaine examine le certificat, lit l'identité qu'il contient, et délivre un TGT pour ce compte.

Tout repose donc sur une question : **l'identité inscrite dans le certificat est-elle digne de confiance ?** Cette identité figure dans un champ nommé le **SAN** — le « Subject Alternative Name ». Et qui remplit le SAN dépend entièrement du **modèle de certificat** utilisé. Un modèle est une fiche de réglages, stockée dans l'annuaire, qui dit qui peut demander ce type de certificat, pour quel usage, et — surtout — qui décide de l'identité.

La faille ESC1 — quatre réglages qui s'alignent

ESC1 n'est pas un bug : c'est une combinaison de quatre réglages parfaitement valides isolément, mais explosive réunie. Quand un même modèle coche les quatre cases ci-dessous, il devient une faille d'élévation directe.



Réunissez ces quatre conditions et le scénario s'écrit tout seul : un compte ordinaire demande un certificat sur ce modèle, et inscrit dans le champ SAN non pas son propre nom, mais `administrateur@adcompagnon.lab`. L'autorité signe sans sourciller — elle ne fait qu'appliquer le modèle. Le demandeur présente alors ce certificat au contrôleur de domaine via PKINIT, et reçoit un TGT d'administrateur du domaine. Sans jamais avoir connu son mot de passe.

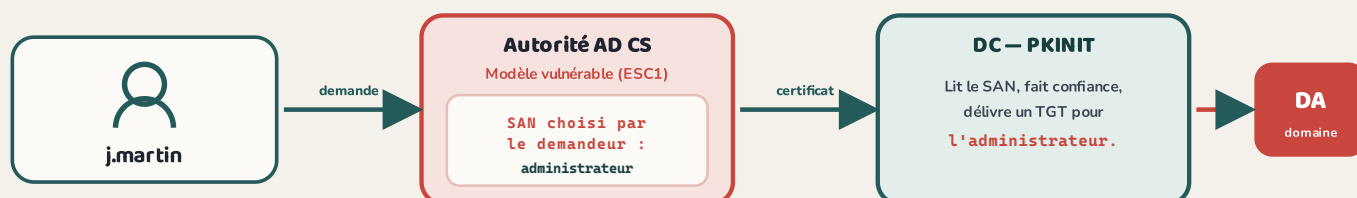


Schéma 1 — ESC1 : le demandeur inscrit l'identité de son choix, l'autorité signe, le domaine y croit.

■ SOUS L'ÉCORCE

« ESC1, c'est une faille parmi d'autres ; je corrige ce modèle et c'est réglé. » — Le réflexe est bon, mais la famille est large. Les chercheurs ont catalogué une série de chemins, d'ESC1 à ESC15 : certains visent les modèles, d'autres la configuration de l'autorité, ses permissions, ou son interface web. ESC8, par exemple, ignore complètement les modèles. Corriger un modèle ne met donc pas la PKI à l'abri — il faut la considérer comme un actif de Tier 0 et l'auditer dans son ensemble.

3

NIVEAU 3 — SUR LE TERRAIN

La salle des machines

Trois gestes, toujours dans le même ordre : **vérifier** l'état de vos modèles, **comprendre** ce qu'un attaquant en ferait, puis **corriger et détecter**.

1 Vérifier

Le diagnostic se fait avec **Certify** (ou son équivalent Python **certipy**) : ces outils énumèrent les modèles publiés et signalent directement ceux qui sont vulnérables. Le commutateur **vulnerable** ne retient que les modèles à risque.

```
● ● ● LA COMMANDE DU JOUR — AUDITER LES MODÈLES DE CERTIFICATS

# Depuis un poste du domaine, avec Certify
PS C:\> .\Certify.exe find /vulnerable

# Variante Python, multiplateforme
$ certipy find -u j.martin@adcompagnon.lab -p '***' -vulnerable -stdout
```

Mot à mot. **find** énumère les modèles publiés ; **/vulnerable** applique les critères connus (dont les quatre conditions d'ESC1) et ne garde que les modèles fautifs. Pour chacun, l'outil affiche le nom, qui a le droit de s'y inscrire, et la raison exacte du signalement. **Tout modèle listé ici est à traiter sans délai.**

```
Certify — énumération des modèles

PS C:\> .\Certify.exe find /vulnerable

[!] Modèle vulnérable

Nom      : ADC-WebServeurAuth
Inscription : ADCOMPAGNON\Utilisateurs du domaine
SAN demandeur : ENROLLEE_SUPPLIES_SUBJECT
EKU      : Client Authentication

PS C:\> █
```

! Les quatre cases

Inscription ouverte, SAN au demandeur, usage d'authentification, aucune approbation : les quatre alignées.

ADC-WebServeurAuth = ESC1.

Capture simulée — Certify sur adcompagnon.lab : un modèle qui réunit les quatre conditions.

2 Comprendre l'attaque

Le modèle vulnérable n'est pas une faille isolée : c'est le premier maillon d'une chaîne courte et fiable. Voici comment un attaquant la déroule.

■ CE QU'UN ATTAQUANT EN FAIT

1 La demande piégée

Avec son compte ordinaire, il réclame un certificat sur le modèle vulnérable — et inscrit dans le champ SAN l'identité visée : `certipy req ... -upn administrateur@adcompagnon.lab`.

2 La signature

L'autorité applique le modèle, ne voit rien d'anormal — le modèle *autorise* ce SAN — et délivre un certificat valide attestant l'identité de l'administrateur.

3 L'authentification

Il présente ce certificat au contrôleur de domaine via PKINIT — `certipy auth` — et reçoit en retour un TGT au nom de l'administrateur du domaine.

4 La persistance

Le certificat reste valable des mois — et survit à une réinitialisation du mot de passe. Au passage, l'authentification PKINIT révèle le condensat NTLM du compte, autre porte dérobée durable.

À chaque maillon, c'est le modèle mal-réglé qui rend le suivant possible. **Corriger le modèle, et la demande piégée**

3 Corriger et détecter

La correction tient en trois gestes. Le premier brise la condition centrale d'ESC1, le deuxième ajoute un garde-fou, le troisième durcit l'autorité elle-même.

1 Reprendre la main sur le SAN

Sur le modèle fautif, retirez le drapeau qui laisse le demandeur fournir le SAN. L'identité du certificat sera désormais construite par l'autorité à partir du compte demandeur — et non plus choisie par lui.

● ● ● RETIRER « LE DEMANDEUR FOURNIT LE SUJET »

```
# Le bit 0x1 de msPKI-Certificate-Name-Flag
# (CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT). Le retirer impose
# un SAN construit par l'autorité, non choisi par le demandeur.
PS C:\> # via la console des modèles, ou l'attribut de l'objet.
```

2 Exiger une approbation

Pour tout modèle d'authentification qui doit rester ouvert, activez « L'approbation du gestionnaire de certificats est requise ». Une émission ne peut plus être automatique : une demande au nom de l'administrateur saute aux yeux du valideur.

3 Durcir l'autorité

Activez l'extension **SID** de sécurité dans les certificats (correctif KB5014754), qui lie le certificat au compte réel et neutralise l'usurpation par le SAN. Retirez les modèles inutilisés, et traitez le serveur AD CS comme un actif de Tier 0.

Détecter — les bons événements

L'autorité journalise chaque émission — à condition d'avoir activé l'audit AD CS. Surveillez deux événements sur le serveur.

ID 4886 « L'autorité de certification a reçu une demande de certificat ». Croisé avec l'événement suivant, il trace toute la séquence d'émission, du dépôt à la délivrance.

ID 4887 « L'autorité de certification a approuvé une demande et délivré un certificat ». L'événement clé : un certificat émis sur un modèle d'authentification où le **demandeur** et l'**identité inscrite** diffèrent est la signature même d'ESC1.

Pour une **chasse proactive**, ce filtre LDAP liste les modèles publiés qui laissent le demandeur fournir le SAN — la condition la plus dangereuse :

● ● ● CHASSE — MODÈLES OÙ LE DEMANDEUR FOURNIT LE SUJET

```
PS C:\> $base = "CN=Certificate Templates,CN=Public Key Services," +
>> "CN=Services,CN=Configuration,DC=adcompagnon,DC=lab"
PS C:\> Get-ADObject -SearchBase $base `
>> -LDAPFilter '(msPKI-Certificate-Name-Flag:1.2.840.113556.1.4.804:=1)' | Select Name
```

OBSERVATEUR D'ÉVÉNEMENTS — JOURNAL SÉCURITÉ (SERVEUR AD CS)

Event ID 4887

Demandeur : ADCOMPAGNON\j.martin
Modèle : ADC-WebServeurAuth
Sujet / SAN : **UPN = administrateur@adcompagnon.lab**
Disposition : Certificat délivré

! Le demandeur et l'identité du certificat diffèrent — signature d'une demande ESC1.

VU SUR LE TERRAIN

Lors de l'audit d'une organisation de taille moyenne, l'équipe de sécurité ne trouve aucune faiblesse dans les groupes ni dans les permissions de l'annuaire. La PKI, elle, n'avait jamais été dans le périmètre : montée des années plus tôt pour le portail Wi-Fi, elle était gérée par l'équipe réseau, sans audit. Une seule exécution de l'outil d'énumération a suffi : un modèle, créé pour les certificats de serveurs web, cumulait l'inscription ouverte et le SAN fourni par le demandeur. En trois commandes, sans connaître le moindre mot de passe à privilèges, l'équipe obtenait un certificat — puis un ticket — d'administrateur du domaine. Le correctif tenait en un drapeau à retirer sur un seul modèle.

LE COIN DU DÉCIDEUR

Une PKI interne n'est pas un équipement réseau : c'est une **source d'identités** que tout le domaine croit sur parole. À ce titre, l'autorité de certification appartient au même niveau de criticité que vos contrôleurs de domaine — le **Tier 0** — et doit être administrée, surveillée et auditée comme tel. La bonne question pour votre équipe n'est pas « nos certificats fonctionnent-ils ? », mais « **quand avons-nous audité nos modèles de certificats pour la dernière fois ?** ». Si la réponse est « jamais », c'est l'angle mort à éclairer en priorité.

L'ÉNIGME DU COMPAGNON — N°04

Sur [adcompagnon.lab](#), l'équipe a fait le ménage : plus aucun modèle ne laisse le demandeur fournir le SAN, et toutes les inscriptions sensibles exigent une approbation. L'audit des modèles est irréprochable. Pourtant, un test d'intrusion obtient encore un certificat d'administrateur. **Comment, si tous les modèles sont sains ?**

LA RÉPONSE DU COMPAGNON

Parce que l'attaque ne passe plus par un modèle : c'est **ESC8**. L'autorité expose souvent une interface web d'inscription en HTTP, qui accepte l'authentification NTLM. L'attaquant force un compte privilégié — typiquement un contrôleur de domaine, via une technique de coercition vue au N°02 — à s'authentifier vers lui, puis *relaie* cette authentification vers l'interface web de l'autorité. Celle-ci, croyant parler au contrôleur de domaine, lui délivre un certificat à ce nom. Aucun modèle vulnérable n'est requis : la faille est dans le point d'inscription web lui-même. La parade : désactiver cette interface si elle est inutile, ou imposer HTTPS avec protection étendue de l'authentification (EPA). Auditer les modèles est nécessaire — mais l'autorité a d'autres portes que ses modèles.

LE GLOSSAIRE

AD CS — Les services de certificats d'Active Directory : la PKI intégrée au domaine.

PKI — infrastructure à clés publiques : l'ensemble qui émet et gère les certificats.

Autorité de certification — le serveur qui signe et délivre les certificats.

Certificat — document signé attestant une identité ou un usage ; sert aussi à s'authentifier.

Modèle de certificat — fiche de réglages, stockée dans l'annuaire, qui définit un type de certificat.

PKINIT — extension de Kerberos permettant d'obtenir un TGT à l'aide d'un certificat.

SAN — Subject Alternative Name : le champ d'un certificat qui porte l'identité attestée.

EKU — Enhanced Key Usage : les usages autorisés d'un certificat, dont l'authentification client.

ESC1 — faille permettant à un demandeur de choisir l'identité inscrite dans son certificat.

ESC8 — relais d'une authentification vers l'interface web d'inscription de l'autorité.

Certipy / Certify — outils d'audit et d'abus des configurations AD CS.

Tier 0 — le niveau des actifs qui contrôlent l'annuaire ; le périmètre le plus protégé.

DANS LE PROCHAIN NUMÉRO



N°05 — Le mot de passe qui ne change jamais : les comptes de service et le Kerberoasting

Comment un simple SPN transforme un vieux compte applicatif en mot de passe à déchiffrer hors ligne.